Universidad de las Fuerzas Armadas ESPE

Departamento de Ciencias de la Computación

Carrera de Ingeniería en Software

Desarrollo de Software Seguro

Proyecto Integrador

Docente: Prof. Geovanny Cudco

21 de abril de 2026

1. Tema

Desarrollo Seguro de una galería multimedia pública con detección de esteganografía y gestión de riesgos en el SDLC.

2. Tipo de actividad

Proyecto Integrador. Combina el desarrollo de una aplicación web funcional con la elaboración de un plan estratégico de seguridad documentado.

3. Contexto

La seguridad del software ha dejado de ser una capa perimetral para convertirse en una propiedad intrínseca del producto. En aplicaciones web modernas que gestionan contenido generado por el usuario (UGC), como galerías públicas, las amenazas no solo provienen de inyecciones SQL o XSS, sino también de vectores más sofisticados como la esteganografía.

En este escenario, un repositorio multimedia aparentemente inofensivo (álbumes de fotos) puede convertirse en un canal encubierto para la exfiltración de datos, la distribución de malware o la coordinación de actividades maliciosas sin ser detectado por firewalls tradicionales. Este proyecto aborda la problemática desde una perspectiva holística: no basta con programar una funcionalidad de "subir imagen"; es necesario aplicar una Gestión de Riesgos formal, entender las vulnerabilidades a todos los niveles (desde el hardware que procesa la imagen hasta la arquitectura de microservicios si la hubiera) y diseñar un software resiliente que mantenga sus propiedades de seguridad incluso bajo ataque.

4. Objetivo

4.1. General

Diseñar e implementar una aplicación web segura y resiliente para la gestión de una galería pública de imágenes, aplicando principios de seguridad a lo largo de todo el ciclo de vida de desarrollo, con un enfoque particular en la mitigación de amenazas de esteganografía y la gestión de accesos basada en roles.

4.2. Específicos:

- Analizar y clasificar amenazas a nivel de código, diseño, arquitectura y hardware que afectan a un repositorio multimedia público.
- Implementar un Plan Estratégico de Seguridad que incluya directrices para las fases de Requisitos, Diseño, Desarrollo, Pruebas y Despliegue (SDLC).
- Desarrollar controles de seguridad perimetral y puntos de ataque, incluyendo validación de entradas, control de acceso basado en roles (RBAC) y gestión segura de sesiones.
- Integrar un módulo de análisis de contenido que permita detectar posibles manipulaciones por esteganografía en archivos de imagen subidos por el usuario.
- Evaluar el coste potencial de las vulnerabilidades en el contexto del negocio (daño reputacional, suplantación de identidad a través de imágenes maliciosas).

5. Descripción de la Actividad

El estudiante actuará como Arquitecto de Software y Desarrollador Full-Stack para construir "SecureFrame Gallery". La actividad se divide en dos grandes componentes:

5.1. Documento de Plan Estratégico de Seguridad

El estudiante deberá redactar un informe que responda a las siguientes preguntas clave, justificando cada decisión técnica desde la óptica de los temas del curso:

- **Introducción y Costes:** ¿Cuál es el coste de una vulnerabilidad de Path Traversal o File Upload Bypass en este sistema? ¿Qué pasaría si una imagen con un payload oculto en sus metadatos o píxeles se vuelve viral en la galería pública?
- **Análisis de Amenazas:** Elaborar una matriz de amenazas categorizadas en:
  - **Hardware:** (Ej. Ataques de canal lateral al procesar imágenes grandes que causan denegación de servicio por uso excesivo de CPU/RAM).
  - **Código:** (Ej. Vulnerabilidades en la librería de procesamiento de imágenes, Buffer Overflow en el parseo de formatos, Inyección de comandos en `exec` de herramientas de análisis).
  - **Diseño:** (Ej. Falta de segregación de roles efectiva entre "Usuario", "Supervisor" y "Visitante").

    - **Arquitectura:** (Ej. Almacenamiento de archivos en el mismo servidor de la aplicación vs. almacenamiento en la nube con políticas IAM).

- **Seguridad en el SDLC:** Detallar qué actividades de seguridad se realizarán en cada fase (Requisitos de Confidencialidad/Integridad, Threat Modeling en Diseño, SAST en Desarrollo, DAST y Fuzzing en Pruebas).

- **Directrices Adicionales y Frameworks:** Mencionar cómo se alinea la solución con estándares como OWASP ASVS (Nivel 2) o NIST SP 800-218 (SSDF). No se pide implementar un framework comercial específico, sino referenciar sus principios.

5.2. Desarrollo de la Aplicación Web

Implementación de la galería con las siguientes particularidades de seguridad.

6. Requisitos Funcionales

RF01: Registro y Autenticación Segura

El sistema permitirá el registro de nuevos usuarios.

- **Control de Seguridad Implícito:** Política de contraseñas robustas, protección contra enumeración de usuarios, almacenamiento de credenciales con salting y hashing fuerte (ej. `Argon2id`), protección contra fuerza bruta (Rate Limiting).

RF02: Gestión de Álbumes (Solicitud y Aprobación)

- El usuario autenticado solicita la creación de un nuevo álbum (Título, Descripción, Privacidad inicial).

- La solicitud queda en estado "Pendiente de Revisión".

- El rol Supervisor/Administrador visualiza un panel con las solicitudes y las aprueba o rechaza.

- **Control de Seguridad Implícito:** Validación estricta de los campos de entrada para prevenir Stored XSS en la descripción del álbum.

RF03: Subida de Imágenes y Detección de Esteganografía (Núcleo del Proyecto)

- Un usuario con álbum aprobado puede subir archivos de imagen.

- **Punto de Control Crítico:** Antes de almacenar definitivamente el archivo o hacerlo visible, el sistema DEBE procesar el archivo para detectar si contiene datos ocultos mediante esteganografía.

- La detección no debe basarse únicamente en la extensión o el MIME Type, sino en un análisis estructural del archivo.

- **Flujo de Validación:**

- Validación de tipo MIME real (*File Magic Numbers*).
- Re-encoding y stripping de metadatos EXIF (Amenaza de Geolocalización / XSS en EXIF).
- Análisis Esteganográfico Automatizado: El sistema ejecutará un proceso (síncrono o asíncrono) que analice el histograma de color, el ruido (análisis LSB - Least Significant Bit) o estructuras de marcadores sospechosos (EOF attacks).
- **Resultado:** Si el análisis devuelve "Sospechoso" o "Positivo", el archivo se pone en cuarentena para revisión manual por el Supervisor. Si es "Limpio", se almacena y se muestra en la galería pública.

RF04: Flujo de Revisión Manual (Supervisor)

- El Supervisor accede a una bandeja de "Imágenes en Cuarentena".
- Puede ver la imagen y los metadatos del análisis automático (por qué fue marcada).
- Decide: "Aprobar (Ignorar alerta)" o "Rechazar (Eliminar archivo)".

RF05: Visualización Pública Segura

- Los visitantes no autenticados pueden navegar por los álbumes aprobados y ver las imágenes.
- **Seguridad Perimetral:** Implementación de `Content Security Policy` (CSP) y cabeceras `X-Content-Type-Options: nosniff` para mitigar ataques de MIME Sniffing y XSS a través de archivos SVG maliciosos disfrazados de imágenes.

7. Entregables

El estudiante deberá entregar un único archivo comprimido o un repositorio que contenga:

- **Código Fuente:** Proyecto completo de la aplicación web.
- **Repositorio de GitHub:** Enlace al repositorio **PÚBLICO** con el historial de *commits* completo. El archivo `README.md` debe incluir:
  - Instrucciones claras de despliegue (variables de entorno necesarias, dependencias).
  - Credenciales de prueba para los roles (Usuario demo, Supervisor demo).
  - Justificación técnica de la librería/método elegido para la detección de esteganografía.
- **Documento de Plan Estratégico (PDF):** Memoria técnica que desarrolle los puntos del Componente A descrito anteriormente (Análisis de Amenazas, Gestión de Riesgos, Seguridad en el SDLC). Extensión máxima: 10 páginas (sin contar portada).

8. Fecha de entrega

12 de mayo, 11h00. No se aceptarán entregas posteriores a esta hora.

Modalidad de Defensa: Las defensas se realizarán de manera aleatoria durante las sesiones de clase del 12 de mayo y 14 de mayo.

Importante: Todos los estudiantes deben tener su proyecto desplegado y funcional en el momento de la entrega. Si un estudiante es seleccionado al azar y su aplicación no está operativa (servidor caído, dependencias rotas), la calificación correspondiente a la defensa oral será de 0.